COMPLY 24

COMPLIANCE INTELLIGENCE · QUICKSCAN

From law to demonstrable evidence.

Example report
DORA · ICT third-party risk

A risk-based gap assessment of contracts, policies and controls, traceable to article, paragraph and source.

FOR

Noordhaven Bank N.V. · fictitious case

Report date 11 October 2026 · reference C24-QS-EX-001 · lead time ten working days

ILLUSTRATIVE EXAMPLE

Example document. All client documents, assessments and findings are fictitious. No assurance opinion.

01 · EXECUTIVE VIEW

The core at a glance

EXECUTIVE CONCLUSION

The basis is there.
Contractual assurance lags behind.

Subcontracting, audit rights, concentration management and exit arrangements in particular need demonstrable improvement.

12	4	5	3
controls assessed	GAP	PARTIAL	COVERED

What this means for the board

- **There is direction.** Policy, vendor selection and SLA monitoring are partly demonstrable.
- **There is exposure.** Four requirements lack a verifiable translation into contracts or processes.
- **There is a workable path.** The findings can be tied to owners, evidence and a 90-day plan.

ADVICE TO MANAGEMENT

Appoint an owner per priority within ten working days and start contractual remediation for critical vendors.

02 · ENGAGEMENT SCOPE

What we assessed

CLIENT AND PERIOD

Noordhaven Bank N.V. (fictitious)
Example period: ten working days

REGULATORY FRAMEWORK

DORA · Regulation (EU) 2022/2554
Focus: ICT service providers and contracts

In scope

- ✓ One theme: management of ICT third parties supporting critical or important functions.
- ✓ Regulation at selected article level: Articles 28, 29 and 30 DORA.
- ✓ Three fictitious internal documents, twelve assessable controls and four priority findings.

Out of scope

- ⚠ No technical penetration test or operating-effectiveness test.
- ⚠ No full legal review of all DORA RTS and ITS.
- ⚠ No formal assurance opinion or guarantee of compliance.

THE QUESTION

Which DORA obligations are relevant to this theme, how are they translated into internal controls, and what do the documents supplied prove — and not yet prove?

The report is a dated snapshot based on the documents within the agreed scope. New legislation and updated internal documents fall outside it.

03 · DOCUMENTS AND METHOD

From source to verdict

D01	**ICT third-party risk policy** Governance, risk appetite, policy	v2.3 · 01 jul 2026
D02	**CloudServ EU – master agreement** Contract with SLA annex, critical ICT service	v4.1 · 12 mei 2026
D03	**ICT vendor register** Vendors, criticality, dependencies	Q3 2026 · 30 sep 2026

⚠ **Important safeguard:** a GAP here means *not demonstrable within the evidence set examined*. It is not a finding that the organisation breaches the law.

The chain in six steps

01 **Law** Provision and paragraph	02 **Obligation** Requirement worked out	03 **Control** Assessable requirement
04 **Evidence** Document and quotation	05 **Verdict** GAP / PARTIAL / COVERED	06 **Action** Owner and deadline

Assessment scale

✓ COVERED	Requirement demonstrably covered in the documents assessed.
⚠ PARTIAL	Element present; essential elaboration or evidence missing.
⚠ GAP	No sufficient substantiation within the scope supplied.

HUMAN-IN-THE-LOOP

The platform supports identification, mapping and draft findings. An authorised reviewer assesses the source, confirms the verdict and records deviations or limitations.

04 · RESULT PER THEME

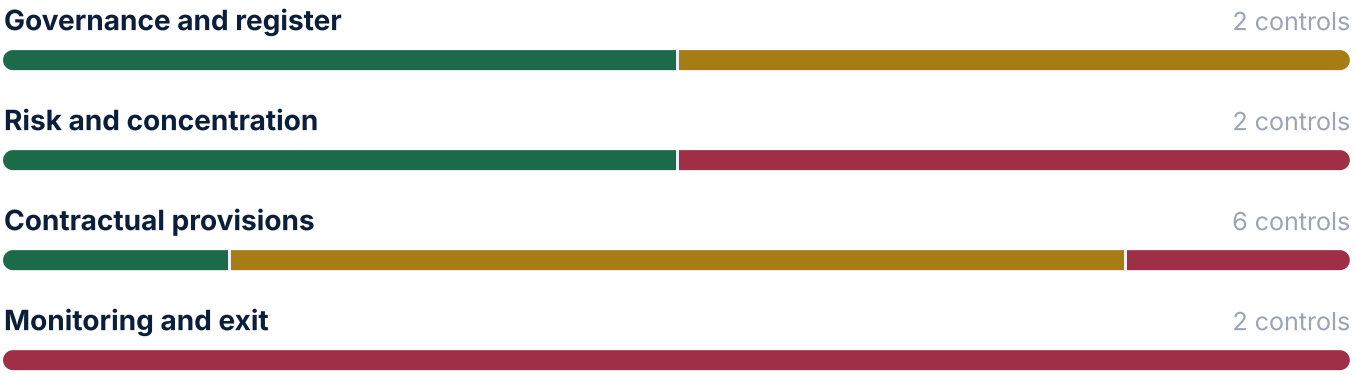
Where the institution stands

25%

3 of the 12 controls were assessed as COVERED; 5 PARTIAL and 4 GAP. This is a scope indicator, not a statement about overall DORA compliance.

● **3** COVERED ● **5** PARTIAL ● **4** GAP

Verdicts per domain



Reading: priorities follow from relevance, impact on critical ICT services and the quality of available evidence. Not from a generic AI score.

05 · CONTROL REGISTER

Article, evidence and status

ID	DORA	CONTROL OR REQUIREMENT	EVIDENCE	STATUS	PRIO
C01	28(1)	Accountability for ICT third parties	D01 §2	✓ COVERED	P3
C02	28(3)	Register of ICT service providers	D03 tab 1	⚠ PARTIAL	P2
C03	28(4)	Risk assessment before contracting	D01 §4	✓ COVERED	P3
C04	29(1)	ICT concentration risk	D03 tab 2	⚠ GAP	P1
C05	30(2)(a)	Scope and conditions for subcontracting	D02 §3.2	⚠ GAP	P1
C06	30(2)(b)	Locations and change notification	D02 §8.1	⚠ PARTIAL	P2
C07	30(2)(c)	Data integrity and confidentiality	D02 §5	⚠ PARTIAL	P2
C08	30(2)(d)	Access, recovery and return of data	D02 §9	⚠ PARTIAL	P2
C09	30(3)(a)	SLA and measurable performance targets	D02 bijl. A §2	✓ COVERED	P3
C10	30(3)(b)	Notification of material developments	D02 §7	⚠ PARTIAL	P2
C11	30(3)(e)	Monitoring and audit rights	D02 §10	⚠ GAP	P1
C12	30(3)(f)	Exit and transition period	D02 §4	⚠ GAP	P1

Legend: P1 = high priority; P2 = plan remediation; P3 = manage and keep assessing. The status concerns only the fictitious documents supplied and may change once further evidence is provided.

06 · FINDING F-01

Subcontracting

RISK PROFILE
HIGH / P1

DORA art. 30(2)(a)

CORE VERDICT

The contract clause broadly permits the use of subcontractors, but the conditions for subcontracting services supporting critical functions are insufficiently determinable.

SOURCE QUOTATION (FICTITIOUS)

> *"The supplier may engage subcontractors where this is necessary for adequate performance of the services." (D02 §3.2)*

WHY THIS MATTERS

The requirement asks for explicit clarity on whether subcontracting is permitted and under which conditions. Without assessable conditions there is no demonstrable control over the chain.

RECOMMENDED REMEDIATION

- ✓ Make permitted subcontracting and its conditions explicit per critical service in the contract annex.
- ✓ Define a prior assessment and notification process for relevant changes.
- ✓ Record approval and reassessment in the ICT vendor register.

RECOMMENDED OWNER

Legal and Procurement together with the third-party risk owner · draft addendum within 30 days

07 · REMEDIATION AGENDA

An approach for the first 90 days

0–15D

Decision and ownership

Appoint P1 owners; prioritise contracts and critical services.

Management / Compliance

15–30D

Contract addenda

Draft and review subcontracting, audit and location clauses.

Legal / Procurement

30–60D

Concentration picture

Record dependencies, substitutability and chain risk.

Risk / Vendor Mgmt

30–75D

Exit plan and test design

Record transition period and test criteria per critical ICT service.

IT / BCM / Security

60–90D

Reassessment and evidence

Reassess findings against new documents and close them.

Compliance / Reviewer

Decision gate after day 90: reconfirm the status against current documents. Close only on demonstrable evidence, not on intended actions.

08 · TRACEABILITY

From law to evidence, in one chain

01 STANDARD
DORA · Article 30(2)(a)

02 OBLIGATION
Subcontracting only under explicit conditions

03 CONTROL
C05 · Described and assessed subcontracting

04 SOURCE
D02 §3.2 · contract version 4.1

05 VERDICT
GAP · F-01 · reviewer confirmed

06 ACTION
Contract addendum and register update · P1

Why this matters: when a source changes, it stays visible which previously confirmed control, conclusion and action must be reviewed again.

A completed result

01
Report received
Framework, gap register, management summary and traceability.

02
Improve
Your team carries out the actions with existing tooling or in its own way.

03
Continue, optionally
With Comply24 the framework is kept up to date and reassessed continuously.

Public sources consulted

Regulation (EU) 2022/2554 (DORA), Art. 28–30
EUR-Lex · CELEX:32022R2554

DORA applies from 17 January 2025
De Nederlandsche Bank · dnb.nl

Registers of information under DORA
European Banking Authority · eba.europa.eu